



Caso de Negocio

Gobierno de TI | IT Governance

Profesora: Palacios Solano Rocío

Grupo 7CV4

Elaboró: Rojo Ibarra Jesús

Periodo Escolar 26/2

Fecha de entrega: 17 de junio de 2026

1. Información General del Proyecto de TI

<i>Nombre del Servicio/ Solución Tecnológica/ proyecto</i>	Servicio de Seguridad Ofensiva para organizaciones vulnerables ante ataques de ciberseguridad	<i>Clave</i>	ID 0001
<i>Fecha Propuesta de Inicio</i>	4 de febrero de 2026	<i>Fecha de Fin de Propuesta</i>	17 de junio de 2026
<i>Nombre del Administrador del Proyecto</i>	Rojo Ibarra Jesús		

2. Antecedentes

Históricamente, la seguridad de las organizaciones se ha basado en modelos defensivos estáticos, utilizando servicios como firewalls o antivirus. Sin embargo, el panorama actual se caracteriza por la profesionalización del cibercrimen. Hoy en día, los atacantes operan con modelos de "Ransomware-as-a-Service", automatización de ataques y una velocidad de ejecución que supera las capacidades de detección manual de una empresa promedio.

Muchas empresas caen en la trampa de la "seguridad de lista de verificación" (checkbox security), donde se cumplen con las normativas (ISO 27001, PCI-DSS), pero aún se mantienen vulnerables en la práctica. Estar certificado no equivale a ser seguro. La seguridad ofensiva rompe esta falsa sensación de seguridad al probar los controles en condiciones reales, revelando qué tan efectiva resulta la postura defensiva ante un adversario motivado.

El estándar actual de la industria es el modelo de "Assume Breach", un enfoque donde se reconoce que, sin importar cuánto se invierta en defensa, es probable que algún actor malicioso encuentre una entrada. La seguridad ofensiva permite a las organizaciones identificar esas entradas antes que los atacantes, transformando una debilidad latente en una oportunidad de mejora continua.

La digitalización acelerada, el trabajo remoto y la adopción de servicios en la nube han expandido drásticamente la superficie de ataque. Ignorar las pruebas ofensivas no elimina el riesgo, solo significa que el primer "test" real al que se enfrentará la empresa será un incidente de seguridad con costos financieros y reputacionales catastróficos.

3. Justificación Técnica del Proyecto

En el contexto actual de transformación digital, las organizaciones dependen críticamente de la tecnología para la continuidad y rentabilidad de sus operaciones. Esta dependencia incrementa la exposición a amenazas cibernéticas que pueden comprometer la confidencialidad, integridad y disponibilidad de la información. Ante este panorama, es fundamental implementar mecanismos proactivos que identifiquen y mitiguen vulnerabilidades antes de que impacten los objetivos estratégicos del negocio.

El servicio de seguridad ofensiva surge como una inversión estratégica para evaluar la resiliencia de la infraestructura tecnológica. Mediante la simulación controlada de técnicas y tácticas utilizadas por atacantes reales, es posible detectar debilidades en sistemas, redes y aplicaciones, previniendo incidentes que podrían resultar en interrupciones operativas, pérdidas financieras o daño reputacional.

A diferencia de los enfoques tradicionales, las evaluaciones ofensivas analizan el entorno desde la perspectiva del atacante, proporcionando a la alta dirección una visión realista y cuantificable del riesgo. Esto facilita la priorización de recursos, la validación de los controles de seguridad existentes y asegura la debida diligencia frente a normativas y regulaciones de cumplimiento.

Asimismo, este tipo de evaluaciones se apoyan en metodologías reconocidas internacionalmente, como las propuestas por OWASP, NIST y el marco MITRE ATT&CK. Esto garantiza un enfoque estructurado y estandarizado que se integra de manera fluida con marcos de Gobierno de TI y gestión de seguridad corporativa, como COBIT o la familia de normas ISO 27000.

Por lo tanto, la implementación de un servicio de seguridad ofensiva no solo representa una validación técnica, sino un componente esencial del Gobierno de TI que optimiza la gestión de riesgos tecnológicos, asegura el cumplimiento normativo y fundamenta la toma de decisiones estratégicas para proteger el valor de la organización.

4. Alcance

El presente servicio está diseñado bajo un enfoque modular, permitiendo a las organizaciones alinear su inversión en ciberseguridad con sus necesidades específicas de

negocio, nivel de madurez y requisitos de cumplimiento normativo. El alcance se define en dos dimensiones: comercial y técnica.

ALCANCE COMERCIAL

- Sector Financiero: Organizaciones que requieren validar la seguridad de sus plataformas transaccionales y cumplir con regulaciones financieras locales e internacionales.
- Comercio Electrónico (E-commerce) y Retail: Empresas que procesan pagos en línea y requieren asegurar los datos de sus clientes para cumplir con estándares de la industria (ej. PCI-DSS).
- Sector Salud: Instituciones que almacenan expedientes clínicos y datos personales altamente confidenciales, sujetos a estrictas leyes de privacidad.

ALCANCE TÉCNICO

- Evaluación de Vulnerabilidades: Análisis automatizado y validación manual de la infraestructura tecnológica expuesta (servidores, redes, bases de datos). Su objetivo es identificar configuraciones deficientes, puertos abiertos y falta de actualizaciones de seguridad.
- Pruebas de Penetración a Aplicaciones Web (Web Pentesting): Simulaciones de ataques dirigidos contra aplicaciones web y portales transaccionales. Se utiliza la metodología OWASP Top 10 para identificar fallos críticos como inyecciones de código, problemas de autenticación y exposición de datos sensibles.
- Simulación de Ingeniería Social: Ejecución de campañas controladas y autorizadas de Phishing dirigidas al personal de la organización. Su propósito es medir el nivel de concientización frente a engaños cibernéticos e identificar vulnerabilidades asociadas al factor humano.

5. Objetivo

Evaluar integralmente la postura de ciberseguridad de las organizaciones cliente, mediante la ejecución controlada de análisis de vulnerabilidades, pruebas de penetración a aplicaciones web y simulaciones de ingeniería social, con el fin de identificar y priorizar riesgos reales antes de que sean explotados por atacantes, fortaleciendo así la resiliencia operativa y el cumplimiento normativo.

6. Riesgos (5)

Descripción del Riesgo	Impacto	Probabilidad
Durante la ejecución de las pruebas de penetración o escaneos de vulnerabilidades, existe la posibilidad de que una herramienta automatizada o un exploit sature los recursos de un servidor, provocando la caída de un servicio crítico (Denegación de Servicio no intencionada) y afectando la operación del negocio.	Alto	Media

El equipo de seguridad ofensiva podría atacar accidentalmente direcciones IP, subdominios o infraestructuras en la nube (como AWS o Azure) que no pertenecen directamente a la organización o para los cuales no se tiene autorización explícita, lo que podría derivar en demandas o violaciones de contratos con proveedores.

Alto

Baja

Al lograr vulnerar un sistema, el equipo evaluador podría tener acceso accidental a bases de datos con información confidencial (datos personales de clientes, información financiera o secretos industriales). Si estos datos se extraen, almacenan o transmiten de forma insegura en los reportes, el servicio mismo se convierte en una brecha de datos.

Alto

Baja

El servicio es tan efectivo que descubre cientos de vulnerabilidades, pero la organización cliente (o el área de TI interna) no tiene el presupuesto, el personal ni el tiempo para corregirlas. Conocer las fallas y no actuar al respecto eleva drásticamente la responsabilidad legal y el riesgo de negligencia corporativa.

Medio

Alta

La alta dirección puede asumir erróneamente que, al pasar un pentest en una aplicación web específica, toda la organización es inmune a ciberataques. Esto puede llevar a una reducción de presupuesto en otras áreas vitales, como la concientización de empleados o la seguridad física.

Medio

Media

7. Beneficios

- I. **Visibilidad Cuantificable del Riesgo Tecnológico:** Al someter la infraestructura a simulaciones de ataques reales, la organización deja de basar su seguridad en suposiciones teóricas y obtiene evidencia empírica sobre sus vulnerabilidades. Esto permite a la alta dirección comprender el impacto real (financiero, operativo y reputacional) que tendría un incidente, facilitando la priorización objetiva para mitigar las brechas más críticas antes de que sean explotadas por atacantes.
- II. **Optimización y Justificación del Presupuesto de Ciberseguridad:** El servicio proporciona datos concretos sobre qué controles preventivos actuales están funcionando y cuáles están fallando. Esto evita el gasto innecesario en herramientas o licencias redundantes y permite al área de TI justificar de manera contundente sus presupuestos futuros basándose en hechos (cerrar brechas comprobadas). Así, se garantiza que la inversión en tecnología y seguridad genere un verdadero retorno de inversión (ROI) al proteger los procesos críticos del negocio.

- III. Aseguramiento del Cumplimiento Normativo y Protección Reputacional:** La ejecución estructurada de evaluaciones de seguridad ofensiva demuestra la "debida diligencia" de la organización frente a auditores, reguladores, socios comerciales y clientes. Este servicio facilita directamente el cumplimiento de marcos normativos y leyes de protección de datos (como ISO 27001, PCI-DSS o regulaciones financieras locales), evitando sanciones legales o multas, y fortaleciendo la confianza y reputación de la marca en el mercado.
- IV. Reducción del Costo por Incidente de Seguridad:** La detección temprana de vulnerabilidades críticas permite evitar incidentes mayores, reduciendo significativamente los costos asociados a brechas de seguridad (investigación, notificación, multas, pérdida de clientes, etc.).
- V. Fortalecimiento de la Cultura de Seguridad:** A través de las campañas de ingeniería social y la concientización posterior, el personal de la organización desarrolla mejores prácticas de seguridad, reduciendo el factor humano como vector de ataque.

8. Personal involucrado

Perfil	Número	Tipo de Contratación
Líder de Proyecto y Gobierno de Seguridad	1	Tiempo completo (indefinido)
Ingeniero de Seguridad Ofensiva (Pentester)	2	Tiempo completo (indefinido)
Analista de Vulnerabilidades	3	Honorarios / Por proyecto

9. Justificación económica (estudio de mercado)

Scitum (Grupo Carso / Telmex)

Es uno de los integradores de ciberseguridad más grandes de la región, enfocado en corporativos de gran tamaño y gobierno.

Fortalezas:

- Respaldo e infraestructura: Cuentan con Centros de Operaciones de Seguridad (SOC) y un músculo financiero enorme.

- Portafolio integral: No solo hacen seguridad ofensiva, sino también defensiva (Blue Team), monitoreo 24/7 y respuesta a incidentes.
- Confianza corporativa: Tienen el peso de la marca para vender a los bancos más grandes e instituciones gubernamentales.

Debilidades (Oportunidades para el servicio):

- Falta de agilidad: Sus procesos de venta, burocracia interna y tiempos de inicio de proyecto suelen ser muy largos.
- Costos elevados: Su estructura operativa hace que sus servicios sean prohibitivos para startups, Fintechs emergentes o clínicas medianas.
- Servicio estandarizado rígido: Suelen vender "paquetes" corporativos que carecen de la atención personalizada.

Fluid Attacks

Es una empresa con fuerte penetración en el mercado latinoamericano, altamente enfocada en seguridad ofensiva, hacking continuo y DevSecOps.

Fortalezas:

- Especialización técnica: Tienen una plataforma propietaria muy robusta para gestionar hallazgos y son expertos en aplicaciones web y móviles.
- Enfoque en Fintechs y SaaS: Tienen gran éxito con empresas de tecnología nativas digitales.
- Certificaciones: Todo su equipo técnico cuenta con certificaciones ofensivas de alto nivel (OSCP, OSCE, etc.).

Debilidades (Oportunidades para el servicio):

- Modelo de "Hacking Continuo": Su modelo de negocio empuja suscripciones anuales de pruebas continuas, lo cual puede ser demasiado complejo o costoso para una empresa tradicional que solo necesita un pentest transaccional de una sola vez.
- Curva de adopción: Su enfoque técnico avanzado puede abrumar a organizaciones con un nivel de madurez en Gobierno de TI muy bajo.

Propuesta de Valor del Servicio

El servicio se posiciona como una alternativa ágil, personalizada y costo-efectiva para PYMES y organizaciones emergentes que no pueden acceder a los precios de Scitum ni requieren la complejidad del modelo de suscripción de Fluid Attacks. Se ofrece un acompañamiento consultivo y un enfoque modular que permite al cliente pagar solo por lo que necesita.

10. Glosario técnico

Assume Breach – Modelo de seguridad y estándar actual de la industria que reconoce y asume que un actor malicioso eventualmente encontrará una entrada, sin importar cuánto se invierta en defensa.

Blue Team – Equipo especializado en seguridad defensiva encargado de proteger infraestructuras, realizar monitoreo 24/7 y responder a incidentes corporativos.

Checkbox Security – Práctica deficiente en la que las organizaciones se enfocan únicamente en cumplir normativas en papel (como certificaciones), generando una falsa sensación de seguridad mientras permanecen vulnerables en la práctica.

COBIT – Marco de referencia utilizado para el Gobierno de TI y la gestión corporativa de la tecnología, con el cual se integran las metodologías de seguridad estructuradas.

Compliance – Aseguramiento y demostración de "debida diligencia" de que una organización cumple con marcos normativos y leyes de protección de datos aplicables, evitando multas y protegiendo su reputación.

Denegación de Servicio (DoS) – Escenario en el que una herramienta automatizada o un exploit satura los recursos de un servidor, provocando la caída o interrupción de un servicio crítico.

DevSecOps – Práctica que consiste en la integración de la seguridad directamente en el ciclo de desarrollo de software.

Exploit – Herramienta o técnica automatizada utilizada para aprovechar una vulnerabilidad en un sistema y comprometerlo.

ISO 27001 – Norma internacional y marco de referencia orientado a la gestión de la seguridad de la información.

MITRE ATT&CK – Marco de referencia reconocido internacionalmente que documenta tácticas y técnicas estructuradas utilizadas por atacantes reales.

NIST – Organización que proporciona marcos y metodologías internacionalmente reconocidas para la evaluación y gestión de ciberseguridad.

OSINT – Inteligencia de fuentes abiertas: técnica de recolección y análisis de información pública disponible sobre una organización.

OWASP – Open Web Application Security Project: organización internacional que emite metodologías de seguridad, destacando su lista "Top 10" para identificar fallos críticos en aplicaciones web.

PCI-DSS – Estándar de seguridad de datos para la industria de tarjetas de pago, indispensable para empresas de comercio electrónico y retail.

Phishing – Técnica de ingeniería social que involucra campañas de engaño cibernético dirigidas al personal para medir su nivel de concientización.

PoC (Prueba de Concepto) – Evidencia técnica elaborada durante la explotación manual que demuestra la existencia, impacto y viabilidad de una vulnerabilidad.

Ransomware-as-a-Service – Modelo operativo profesionalizado del cibercrimen moderno que permite la automatización de ataques con una velocidad de ejecución alta.

RoE (Reglas de Compromiso) – Definición de las reglas y alcance bajo las cuales se ejecutarán las pruebas de seguridad.

SOC – Centro de Operaciones de Seguridad: infraestructura y equipo dedicado a la detección, monitoreo y prevención de amenazas cibernéticas.

Web Pentesting – Pruebas de penetración a aplicaciones web: servicio que realiza simulaciones de ataques dirigidos específicamente contra aplicaciones web y portales transaccionales.